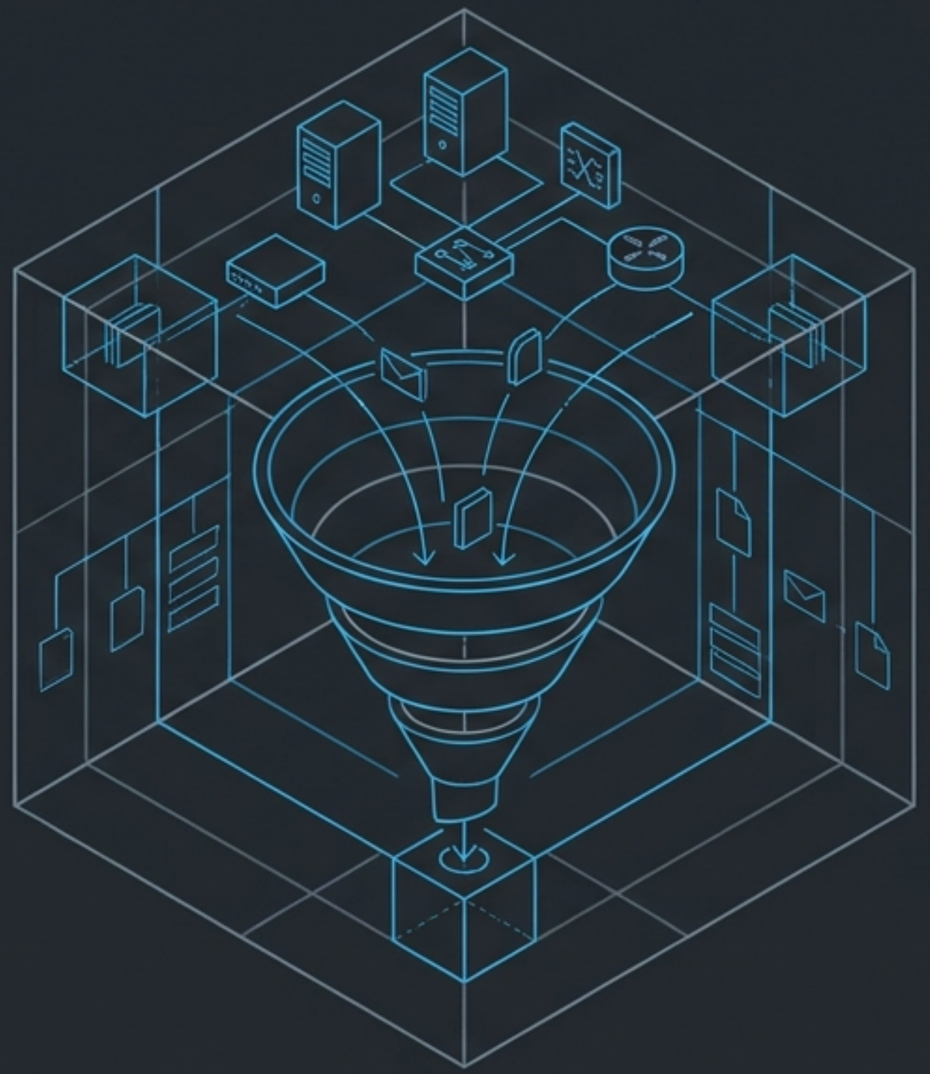
Defesa de Rede Cisco: A Jornada do Analista SOC

Visibilidade, Telemetria e Avaliação de Ameaças (Módulos 9, 10 e 11)

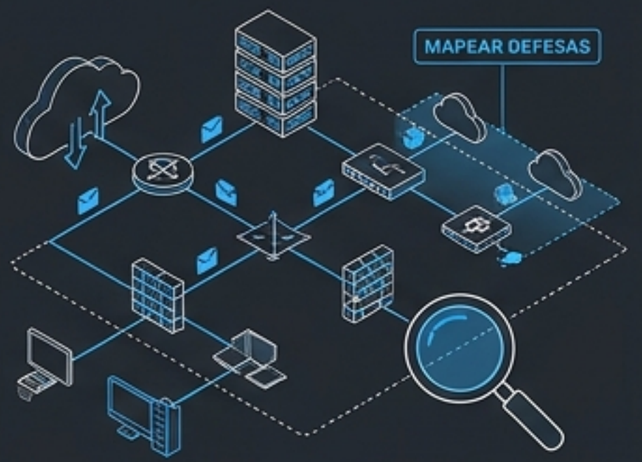


Gemini Notebook

A Jornada da Defesa

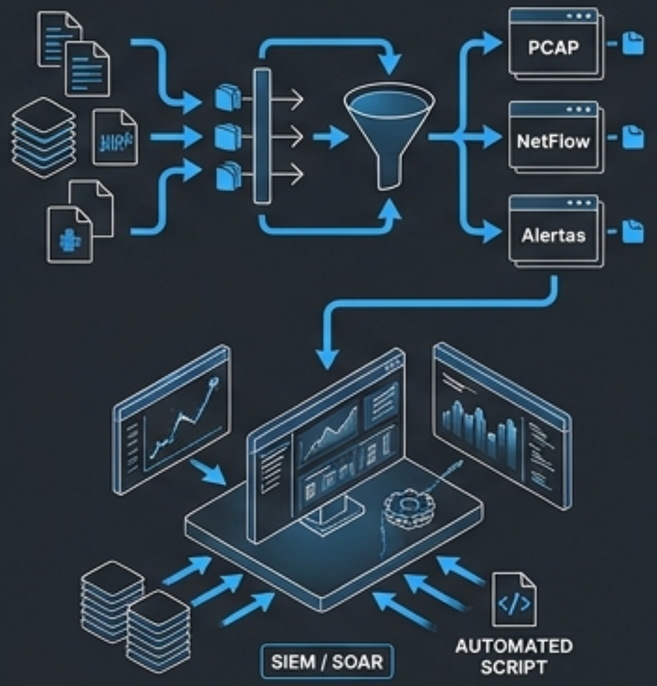
1. Infraestrutura e **Visibilidade** (Módulo 9)

Compreender como a rede se comunica, identificar pontos cegos e mapear as defesas de perímetro.



2. Telemetria e Logs (Módulo 10)

Transformar tráfego bruto em dados estruturados (PCAP, NetFlow, Alertas) e orquestrá-los (SIEM/SOAR).



3. Detecção e Triagem (Módulo 11)

Aplicar motores de intrusão, avaliar alertas em interfaces de análise e separar ameaças reais de ruído.



Gemini Notebook

O Ponto Cego dos Protocolos Comuns

Protocolo	Uso Legítimo	Vetor de Ameaça Comum
DNS	Resolução de nomes.	Exfiltração de dados (codificação Base64) e comunicação C&C.
NTP	Sincronização de relógios.	Amplificação de DDoS e corrupção de timestamps em logs.
ICMP	Diagnóstico de rede (Ping).	Túneis de exfiltração (ex: LOKI) ofuscados em pacotes de echo reply.
E-mail (SMTP/IMAP)	Comunicação corporativa.	Entrada de malware via anexos e exfiltração silenciosa de arquivos.
HTTP	Navegação web.	Injeção de iFrame invisível executando código malicioso.

Gemini Notebook

Navegando no Escuro: Ofuscação de Tráfego

Criptografia HTTPS

Ocultação de Payload

Adiciona camada SSL/TLS, tornando o tráfego ilegível. Exige interceptação com Secure Socket Proxy para inspecionar pacotes antes de entrarem na rede corporativa.



Roteamento Tor

Ocultação de Destino

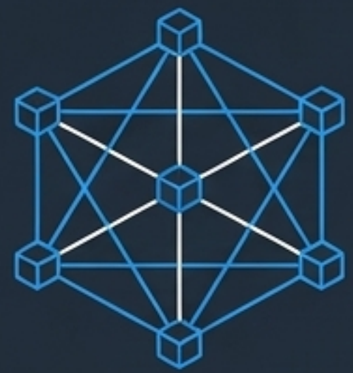
Tráfego roteado por múltiplos nós criptografados. O destino é ofuscado; o analista vê apenas a conexão com o próximo nó de retransmissão.



Redes P2P

Evasão Descentralizada

Hosts operam como clientes e servidores simultaneamente (ex: BitTorrent). Ausência de servidor central dificulta o bloqueio e monitoramento por IP/Domínio.



Gemini Notebook

O Perímetro Filtrado: Camadas de Defesa

1. ACLs (Listas de Controle de Acesso)

Filtragem estática baseada em endereços IP, portas e protocolos. Vulnerável a IP spoofing.



2. NAT e PAT (Conversão de Endereços)

Oculta IPs internos roteando tráfego por IPs públicos. Complica a atribuição de incidentes via NetFlow.



3. Firewalls NGFW e Proxies

Fornece visibilidade profunda de camada 7, inspeção NGIPS, Cisco AMP e filtragem de reputação de URL.



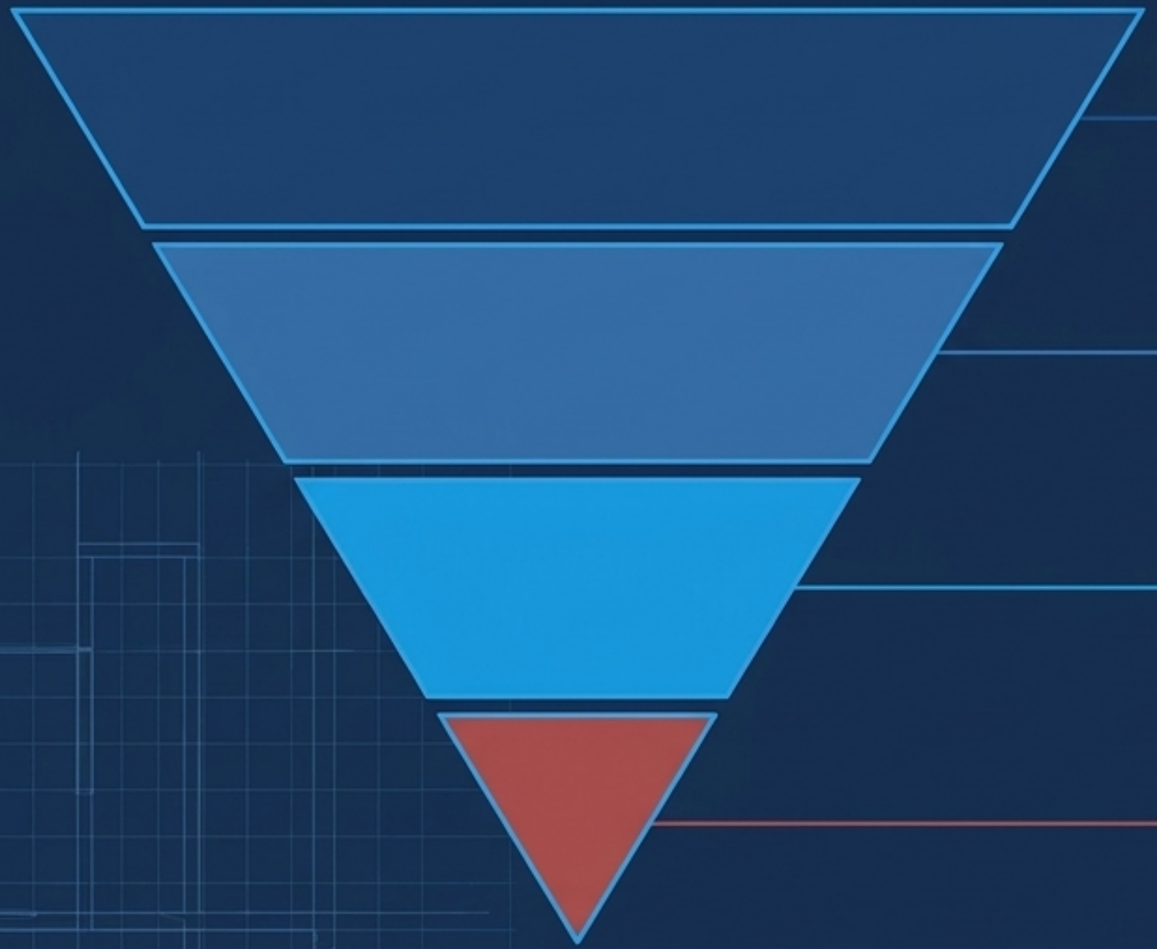
4. Criptografia VPN

Protege os dados remotos em trânsito ponta-a-ponta através de redes públicas e não confiáveis.



Gemini Notebook

A Pirâmide dos Dados de Segurança



Captura Completa (PCAP):

Cópia exata de todos os pacotes. Reconstrução total, exige armazenamento massivo. (Retenção em dias).

Dados de Sessão (NetFlow/IPFIX):

Metadados: IPs, portas, tempo, bytes. Como uma conta de telefone. (Retenção em meses).

Dados de Transação:

Logs detalhados de requisições L7 (ex: cabeçalhos HTTP, consultas DNS). Gerados por Zeek.

Dados de Alerta:

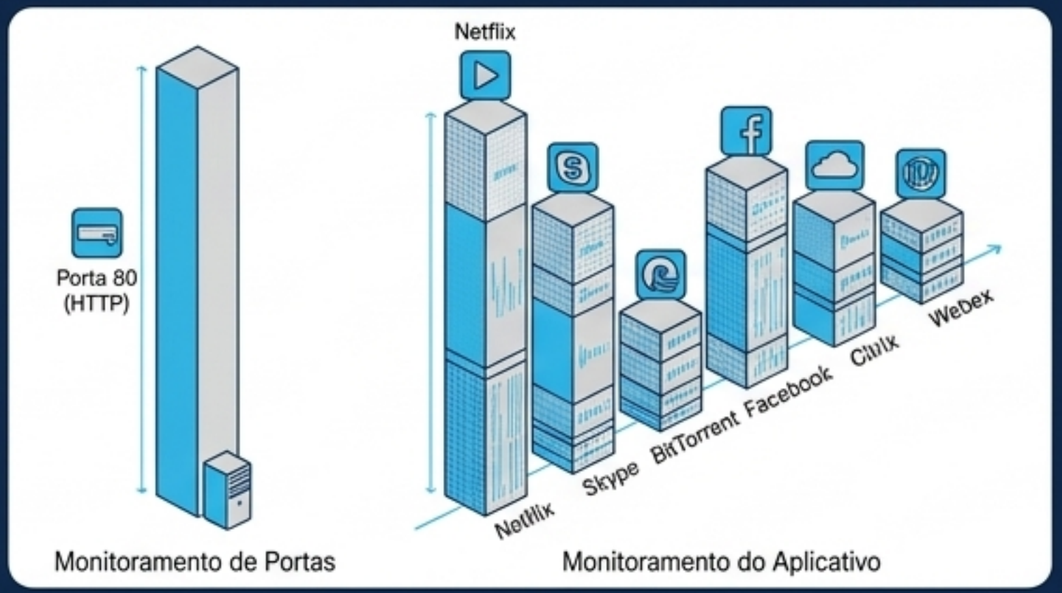
Eventos acionados por regras de IDS (Snort). Baixíssimo volume, altíssimo valor tático e investigativo imediato.

Gemini Notebook

Dispositivos de Visibilidade Avançada

Cisco AVC (Application Visibility and Control)

Monitoramento tradicional confia apenas em portas (ex: TCP 80). O AVC com NBAR2 realiza Inspeção Profunda de Pacotes (DPI) para reconhecer o aplicativo real (ex: Skype, Netflix), não importando a porta.



Proxies de Web e E-mail (WSA/ESA)

WSA (Web): Intercepta tráfego proxy, aplicando políticas de uso aceitável, reputação e DLP.

ESA (E-mail): Monitora SMTP/POP3/IMAP para bloquear SPAM, analisar anexos e rastrear exfiltração em mensagens corporativas.

Gemini Notebook

Fundações de Logs: Host e Servidor



Logs de Sistema Windows

A base da auditoria. Monitora pilares: Aplicativos, Segurança, Sistema e Eventos Encaminhados.



Sistemas HIDS (Wazuh/OSSEC)

Agentes instalados diretamente nos endpoints. Monitoram integridade de arquivos (FIM) e processos ativos.



Servidor de Logs Centralizado



Logs de Servidor (UNIX/Linux)

Uso do daemon syslog (UDP 514). Inclui logs vitais de servidores web (Apache/IIS) para rastrear injeções L7.

Gemini Notebook

Orquestrando a Telemetria: SIEM e SOAR

1. Coleta & Normalização

Recebe logs de várias origens e converte em um modelo de dados comum.

2. Agregação

Reduz o volume consolidando eventos duplicados.

3. Correlação

Vincula logs díspares para detectar um padrão de ataque complexo.

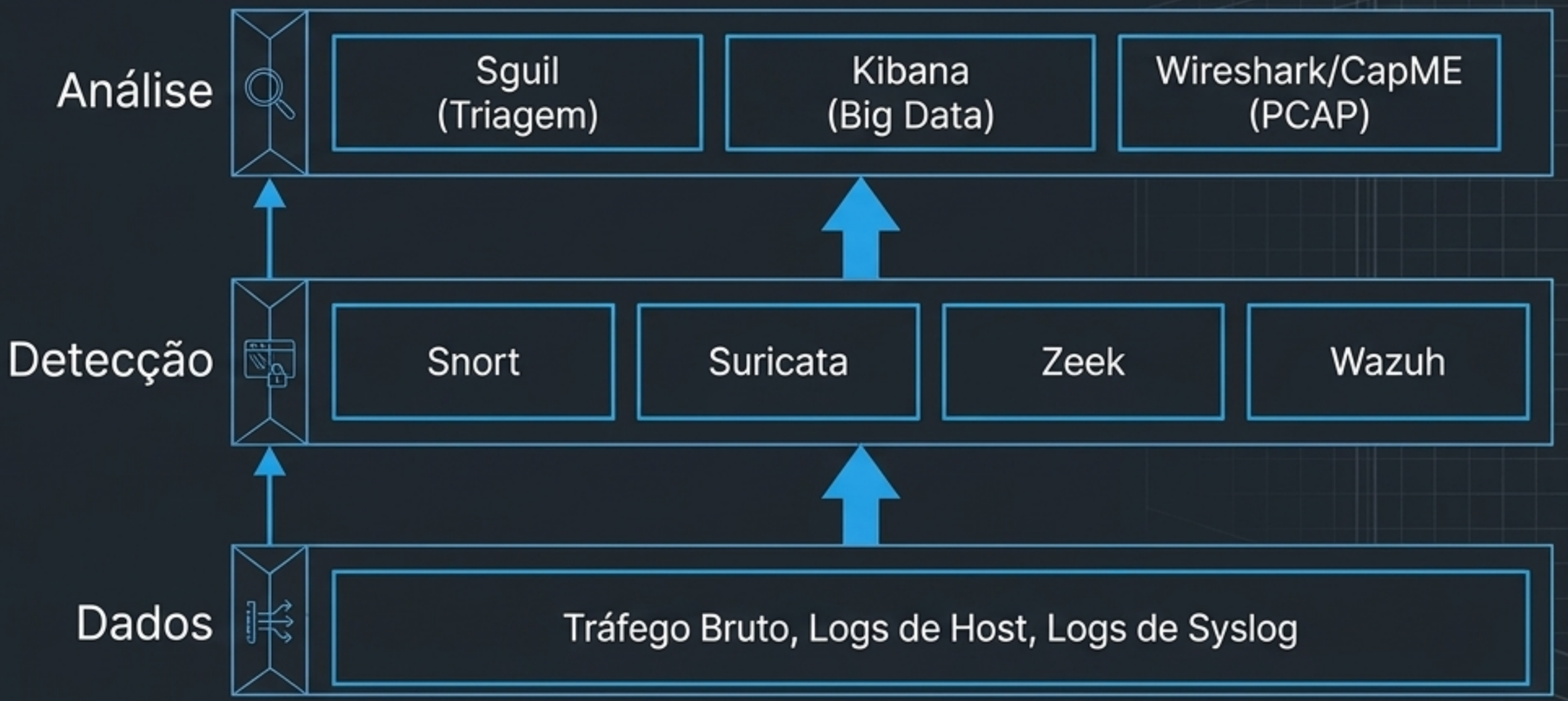


A Resposta do SOAR

Automatiza a resposta a incidentes (ex: isolamento de host) baseada nos alertas gerados pelo SIEM, reduzindo o trabalho manual.

Gemini Notebook

O Ecossistema Security Onion



O Security Onion é uma suíte de Monitoramento de Segurança de Rede (NSM) que une coleta, detecção estruturada e interfaces visuais avançadas em uma única plataforma integrada.

Gemini Notebook

Motores de Detecção de Rede



Snort

NIDS Clássico (Single-thread)

Compara o tráfego da rede contra um enorme banco de dados de regras textuais e assinaturas conhecidas. Excelente e preciso para exploits já catalogados.



Suricata

NIDS Moderno (Multi-thread)

Uso de assinaturas nativo (compatível com Snort), mas distribui o processamento entre vários núcleos de CPU. Essencial para analisar links de rede de altíssima velocidade sem perda de pacotes.



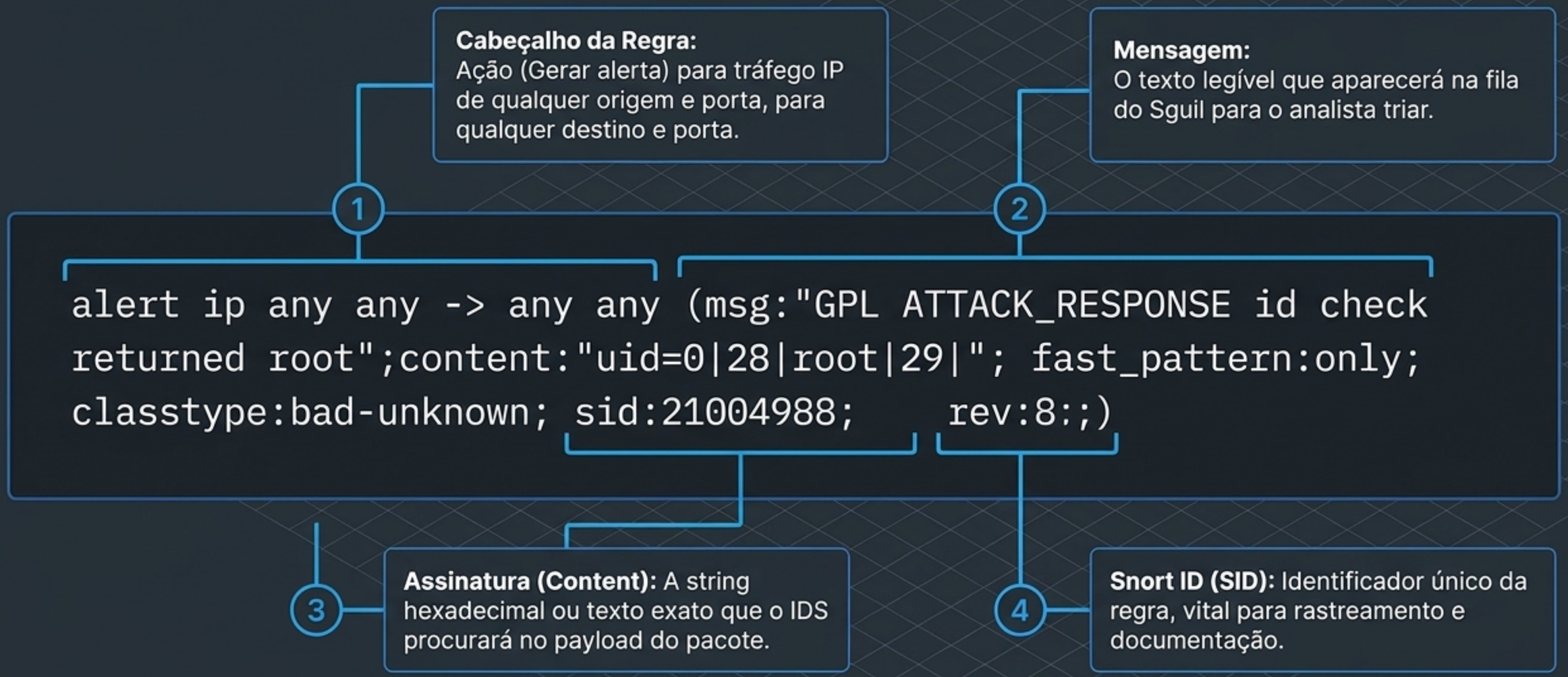
Zeek (antigo Bro)

Analisador Comportamental L7

Não depende exclusivamente de assinaturas. Usa scripts lógicos para monitorar anomalias e gera logs transacionais extremamente ricos da camada de aplicação.

Gemini Notebook

Anatomia de uma Regra Snort



Gemini Notebook

Interfaces de Análise do Analista SOC

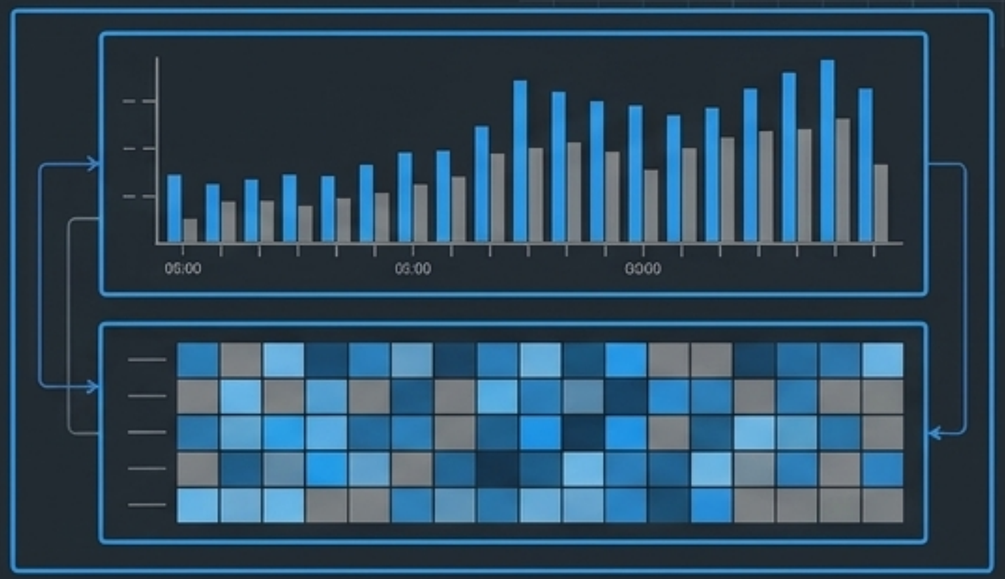
Sguil (Triagem Tática - Tier 1)

Focado em eventos determinísticos (alertas do Snort). Interface estruturada para classificar, escalar ou descartar alertas pendentes.

ST	CNT	Sensor	Source IP	Dest IP
	5	sensor_01	192.168.1.10	10.0.0.5
	5	sensor_01	192.168.1.10	10.0.0.5
	5	sensor_01	192.168.1.10	10.0.0.3
	5	sensor_01	192.168.1.15	10.0.0.5
	5	sensor_01	192.168.1.10	10.0.0.5
	5	sensor_01	192.168.1.18	10.0.0.5

Kibana (Exploração de Big Data)

Focado em análise probabilística e caça a ameaças. Interface interativa baseada no Elasticsearch para gerar consultas complexas, pivots e gráficos de tendência L7.

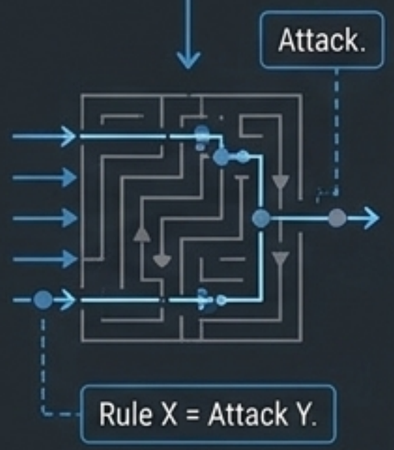


Gemini Notebook

Metodologias de Análise

Análise Determinística

- **Fundação:** Baseada em regras fixas e assinaturas (ex: Snort).
- **Lógica:** "Se o padrão X exato for visto, então é o ataque Y".
- **Vantagem:** Altamente preciso para ataques já conhecidos; não gera Falsos Positivos se a regra for rigorosa.
- **Desvantagem:** Totalmente cego contra ataques novos (Zero-Days) ou ofuscados.



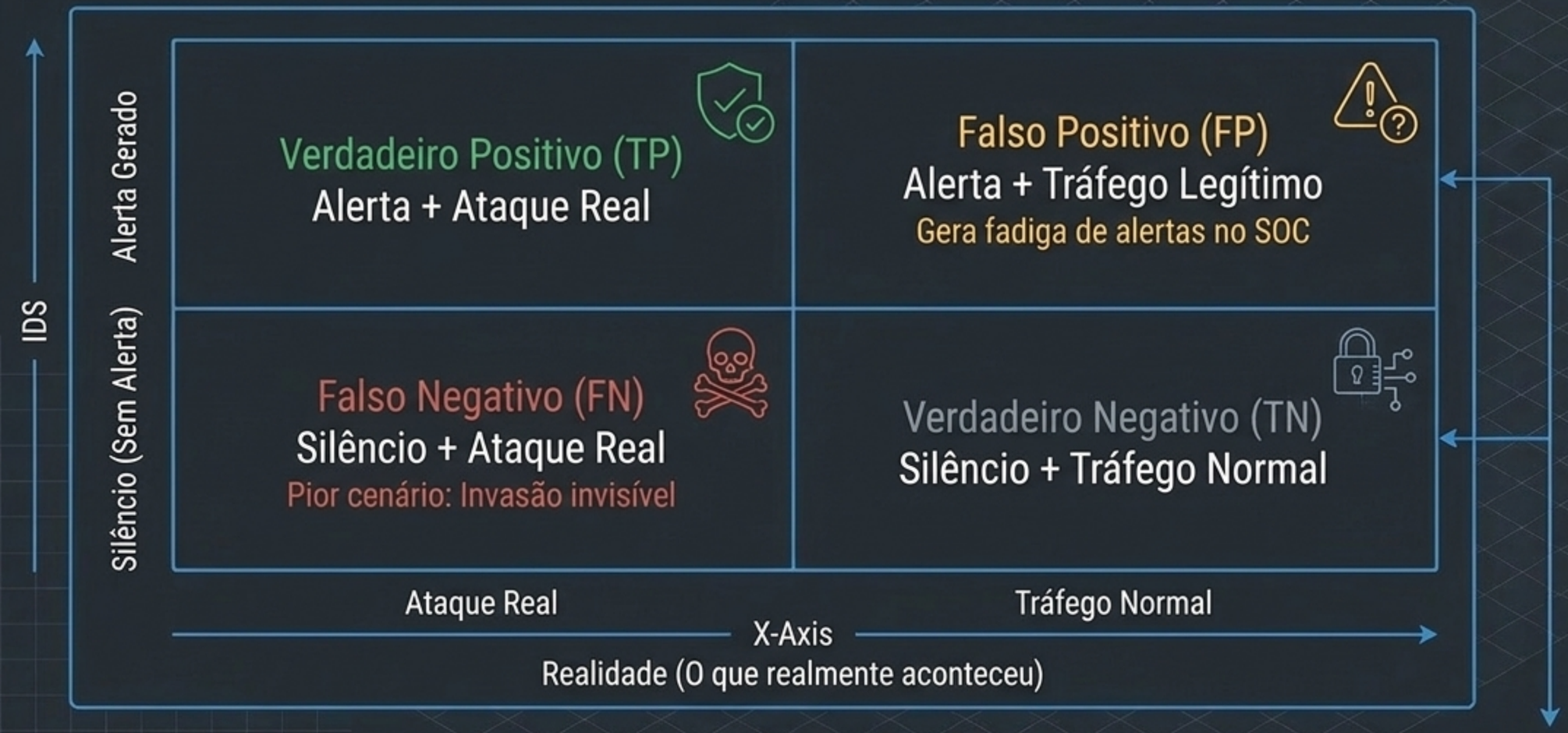
Análise Probabilística

- **Fundação:** Baseada em estatística, comportamentos de protocolo (ex: Zeek).
- **Lógica:** Estuda a linha de base (baseline) e alerta sobre desvios estatisticamente improváveis.
- **Vantagem:** Única forma viável de detectar ataques novos, furtivos e evasões avançadas.
- **Desvantagem:** Gera altas taxas de Falsos Positivos durante mudanças legítimas na rede corporativa.



Gemini Notebook

O Veredito do Analista: Matriz de Eficácia



O objetivo da arquitetura de defesa é maximizar TPs, zerar FNs e afinar regras continuamente para poupar a equipe da fadiga de FPs.

Gemini Notebook